



# Offchain Labs Arbitrum Chains Genesis File Generator

Security Assessment (Summary Report)

August 10, 2026

*Prepared for:*

**Harry Kalodner, Steven Goldfeder, and Ed Felten**

Offchain Labs

*Prepared by:* **Simone Monica and Jaime Iglesias**

# Table of Contents

---

|                                         |           |
|-----------------------------------------|-----------|
| <b>Table of Contents</b>                | <b>1</b>  |
| <b>Project Summary</b>                  | <b>2</b>  |
| <b>Project Targets</b>                  | <b>3</b>  |
| <b>Executive Summary</b>                | <b>4</b>  |
| <b>Summary of Findings</b>              | <b>5</b>  |
| <b>Detailed Findings</b>                | <b>6</b>  |
| 1. Missing EntryPoint v0.9.0 deployment | 6         |
| <b>A. Vulnerability Categories</b>      | <b>8</b>  |
| <b>B. Code Quality Findings</b>         | <b>10</b> |
| <b>C. Fix Review Results</b>            | <b>11</b> |
| <b>D. Fix Review Status Categories</b>  | <b>12</b> |
| <b>About Trail of Bits</b>              | <b>13</b> |
| <b>Notices and Remarks</b>              | <b>14</b> |

# Project Summary

---

## Contact Information

The following project manager was associated with this project:

**Mary O'Brien**, Project Manager  
[mary.obrien@trailofbits.com](mailto:mary.obrien@trailofbits.com)

The following engineering director was associated with this project:

**Benjamin Samuels**, Engineering Director, Blockchain  
[benjamin.samuels@trailofbits.com](mailto:benjamin.samuels@trailofbits.com)

The following consultants were associated with this project:

**Simone Monica**, Consultant  
[simone.monica@trailofbits.com](mailto:simone.monica@trailofbits.com)

**Jaime Iglesias**, Consultant  
[jaime.iglesias@trailofbits.com](mailto:jaime.iglesias@trailofbits.com)

## Project Timeline

The significant events and milestones of the project are listed below.

| Date            | Event                                                     |
|-----------------|-----------------------------------------------------------|
| March 25, 2026  | Delivery of report draft                                  |
| April 2, 2026   | Delivery of final summary report                          |
| April 14, 2026  | Completion of fix review                                  |
| August 10, 2026 | Delivery of final summary report with fix review appendix |

# Project Targets

---

The engagement involved reviewing and testing the following target.

## Genesis File Generator

Repository <https://github.com/OffchainLabs/genesis-file-generator>

Version 456a56b1dc32cb3fd287d443c5573bae5862b597

23722d138e3c40173a9c849dcf6d6cb402f36f58

PR #11

PR #12

Type Solidity

Platform EVM

# Executive Summary

---

## Engagement Overview

Offchain Labs engaged Trail of Bits to review the security of its genesis file generator.

A team of two consultants conducted the review from March 19 to March 20, 2026, for a total of four engineer-days of effort. With full access to source code and documentation, we performed static and dynamic testing of the target, using both automated and manual processes.

## Observations and Impact

The review focused on commit `456a56b1dc32cb3fd287d443c5573bae5862b597`, particularly its diff against the previous version, `59f69a966d343f089d106c931f2ce9c7ee1218d6`.

The latest version introduced a number of changes, such as additional predeployed contracts, additional script flags, a Dockerfile, and other minor changes.

We identified only one minor finding, related to the versions of the ERC-4337 EntryPoint contract available for deployment (**TOB-GENFG-1**).

## Recommendations

Based on the findings identified during the security review, Trail of Bits recommends that Offchain Labs take the following steps:

- **Remediate the finding disclosed in this report.** This finding should be addressed through direct fixes or broader refactoring efforts.
- **Track releases of predeployed contracts.** Tracking releases of predeployed contracts will help the Offchain Labs team notice security fixes or new features in a newer version, promptly add that new version, and eventually deprecate the older version.

## Summary of Findings

---

The table below summarizes the findings of the review, including details on type and severity.

| ID | Title                                | Type          | Severity |
|----|--------------------------------------|---------------|----------|
| 1  | Missing EntryPoint v0.9.0 deployment | Configuration | Low      |

# Detailed Findings

## 1. Missing EntryPoint v0.9.0 deployment

Severity: Low

Difficulty: Low

Type: Configuration

Finding ID: TOB-GENFG-1

Target: `PredeployConstants.sol`, `Predeploys.s.sol`

### Description

The genesis file generator predeploys ERC-4337 EntryPoint contracts at versions 0.6.0, 0.7.0, and 0.8.0, but not 0.9.0. EntryPoint v0.9.0 patches a griefing vulnerability present in all earlier versions that allows an attacker to force valid, correctly signed UserOperations to fail while still draining gas from the victim or paymaster.

The root cause is that `handleOps` and `handleAggregatedOps` accept calls from any address, including contracts. An adversary can invoke them from within their own contract's execution while a temporary blocking condition is active (e.g., reentrancy guard). The victim's UserOperation would execute inside the attacker-controlled call stack and revert due to the manufactured condition; the victim or paymaster would be charged the full gas cost despite the operation being legitimately signed and well formed.

EntryPoint v0.9.0 mitigates this by restricting `handleOps` and `handleAggregatedOps` to EOA callers only via `require(msg.sender == tx.origin)`, which breaks the attacker's ability to nest the call inside a contract execution context. The fix is backward-compatible with existing accounts and paymasters.

### Exploit Scenario

Alice submits a UserOperation targeting a protocol that uses a paymaster. Bob (an attacker) deploys a contract and activates a blocking condition on a contract Alice's operation depends on (e.g., via reentrancy guard activation or a flash loan). Bob's contract calls `EntryPoint.handleOps([Alice's UserOp])` mid-execution. Alice's UserOperation reverts due to the temporary blocking condition. The paymaster (or Alice) is charged full gas fees despite Alice's operation being valid. Bob repeats the attack at low cost, continuously griefing Alice's operations.

### Recommendations

Short term, add EntryPoint v0.9.0 to the list of predeployed contracts alongside the existing v0.6.0, v0.7.0, and v0.8.0 deployments.

## References

- [ERC-4337 bug disclosure](#)



## A. Vulnerability Categories

---

The following tables describe the vulnerability categories, severity levels, and difficulty levels used in this document.

| Vulnerability Categories |                                                         |
|--------------------------|---------------------------------------------------------|
| Category                 | Description                                             |
| Access Controls          | Insufficient authorization or assessment of rights      |
| Auditing and Logging     | Insufficient auditing of actions or logging of problems |
| Authentication           | Improper identification of users                        |
| Configuration            | Misconfigured servers, devices, or software components  |
| Cryptography             | A breach of system confidentiality or integrity         |
| Data Exposure            | Exposure of sensitive information                       |
| Data Validation          | Improper reliance on the structure or values of data    |
| Denial of Service        | A system failure with an availability impact            |
| Error Reporting          | Insecure or insufficient reporting of error conditions  |
| Patching                 | Use of an outdated software package or library          |
| Session Management       | Improper identification of authenticated users          |
| Testing                  | Insufficient test methodology or test coverage          |
| Timing                   | Race conditions or other order-of-operations flaws      |
| Undefined Behavior       | Undefined behavior triggered within the system          |

| Severity Levels |                                                                                                        |
|-----------------|--------------------------------------------------------------------------------------------------------|
| Severity        | Description                                                                                            |
| Informational   | The issue does not pose an immediate risk but is relevant to security best practices.                  |
| Undetermined    | The extent of the risk was not determined during this engagement.                                      |
| Low             | The risk is small or is not one the client has indicated is important.                                 |
| Medium          | User information is at risk; exploitation could pose reputational, legal, or moderate financial risks. |
| High            | The flaw could affect numerous users and have serious reputational, legal, or financial implications.  |

| Difficulty Levels |                                                                                                                                                             |
|-------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Difficulty        | Description                                                                                                                                                 |
| Not Applicable    | This issue is of informational severity and does not pose an immediate risk, so difficulty does not apply.                                                  |
| Undetermined      | The difficulty of exploitation was not determined during this engagement.                                                                                   |
| Low               | The flaw is well known; public tools for its exploitation exist or can be scripted.                                                                         |
| Medium            | An attacker must write an exploit or will need in-depth knowledge of the system.                                                                            |
| High              | An attacker must have privileged access to the system, may need to know complex technical details, or must discover other weaknesses to exploit this issue. |

## B. Code Quality Findings

---

The following findings are not associated with any specific vulnerabilities. However, fixing them will enhance code readability and may prevent the introduction of vulnerabilities in the future.

- `GenerateGenesis.s.sol` hard-codes `MaxCodeSize` and `MaxInitCodeSize` to Nitro's default values in the serialized chain configuration.

Since Nitro uses these exact values as defaults when the fields are absent from the genesis JSON, explicitly including them is redundant. More importantly, it is error-prone: if Nitro's default values ever change, this script would need to be updated manually to stay in sync, and a mismatch could go unnoticed.

```
string.concat(  
    '{"chainId":',  
    vm.toString(chainId),  
    // ...  
    ', "GenesisBlockNum":0, "MaxCodeSize":24576, "MaxInitCodeSize":49152}}'  
)
```

*Figure B.1: Part of the JSON configuration generation in  
`GenerateGenesis.s.sol`#L78–87*

- `arbOSVersion` is read from the environment and parsed with `vm.parseUint`, which returns a `uint256`. However, Nitro will parse this value into a `uint64`. If the provided value exceeds `type(uint64).max`, the overflow will be caught only at configuration parsing time in Nitro, not at genesis generation time. It is preferable to catch this error early, during generation.

```
string memory arbOSVersionStr = vm.envString("ARBOS_VERSION");  
arbOSVersion = vm.parseUint(arbOSVersionStr);
```

*Figure B.2: Part of the JSON configuration generation in  
`GenerateGenesis.s.sol`#L29–L30*

## C. Fix Review Results

---

When undertaking a fix review, Trail of Bits reviews the fixes implemented for issues identified in the original report. This work involves a review of specific areas of the source code and system configuration, not a comprehensive analysis of the system.

On April 14, 2026, Trail of Bits reviewed the fix implemented by the Offchain Labs team for the issue identified in this report. We found that Offchain Labs resolved the issue.

For additional information, please see the Detailed Fix Review Results below.

| ID | Title                                | Severity | Status   |
|----|--------------------------------------|----------|----------|
| 1  | Missing EntryPoint v0.9.0 deployment | Low      | Resolved |

### Detailed Fix Review Results

#### **TOB-GENFG-1: Missing EntryPoint v0.9.0 deployment**

Resolved in [PR #11](#).

## D. Fix Review Status Categories

---

The following table describes the statuses used to indicate whether an issue has been sufficiently addressed.

| Fix Status         |                                                                    |
|--------------------|--------------------------------------------------------------------|
| Status             | Description                                                        |
| Undetermined       | The status of the issue was not determined during this engagement. |
| Risk Accepted      | The issue was acknowledged by the client.                          |
| Unresolved         | The issue persists and has not been resolved.                      |
| Partially Resolved | The issue persists but has been partially resolved.                |
| Resolved           | The issue has been sufficiently resolved.                          |

## About Trail of Bits

---

Founded in 2012 and headquartered in New York, Trail of Bits provides technical security assessment and advisory services to some of the world's most targeted organizations. We combine high-end security research with a real-world attacker mentality to reduce risk and fortify code. With 100+ employees around the globe, we've helped secure critical software elements that support billions of end users, including Kubernetes and the Linux kernel.

We maintain an exhaustive list of publications at <https://github.com/trailofbits/publications>, with links to papers, presentations, public audit reports, and podcast appearances.

In recent years, Trail of Bits consultants have showcased cutting-edge research through presentations at CanSecWest, HCSS, Devcon, Empire Hacking, GrrCon, LangSec, NorthSec, the O'Reilly Security Conference, PyCon, REcon, Security BSides, and SummerCon.

We specialize in software testing and code review assessments, supporting client organizations in the technology, defense, blockchain, and finance industries, as well as government entities. Notable clients include HashiCorp, Google, Microsoft, Western Digital, Uniswap, Solana, Ethereum Foundation, Linux Foundation, and Zoom.

To keep up with our latest news and announcements, please follow [@trailofbits on X](#) or [LinkedIn](#) and explore our public repositories at <https://github.com/trailofbits>. To engage us directly, visit our "Contact" page at <https://www.trailofbits.com/contact> or email us at [info@trailofbits.com](mailto:info@trailofbits.com).

### **Trail of Bits, Inc.**

228 Park Ave S #80688

New York, NY 10003

<https://www.trailofbits.com>

[info@trailofbits.com](mailto:info@trailofbits.com)

# Notices and Remarks

---

## Copyright and Distribution

© 2026 by Trail of Bits, Inc.

All rights reserved. Trail of Bits hereby asserts its right to be identified as the creator of this report in the United Kingdom.

Trail of Bits considers this report public information; it is licensed to Offchain Labs under the terms of the project statement of work and has been made public at Offchain Labs' request. Material within this report may not be reproduced or distributed in part or in whole without Trail of Bits' express written permission.

The sole canonical source for Trail of Bits publications is the [Trail of Bits Publications page](#). Reports accessed through sources other than that page may have been modified and should not be considered authentic.

## Test Coverage Disclaimer

Trail of Bits performed all activities associated with this project in accordance with a statement of work and an agreed-upon project plan.

Security assessment projects are time-boxed and often rely on information provided by a client, its affiliates, or its partners. As a result, the findings documented in this report should not be considered a comprehensive list of security issues, flaws, or defects in the target system or codebase.

Trail of Bits uses automated testing techniques to rapidly test software controls and security properties. These techniques augment our manual security review work, but each has its limitations. For example, a tool may not generate a random edge case that violates a property or may not fully complete its analysis during the allotted time. A project's time and resource constraints also limit their use.